RHEL 9 - DISA STIG

Exception & Unresolved Findings Report

Target System: 192.168.186.129 **Profile:** DISA STIG for RHEL 9 **Scan Date:** 21 April 2026

Executive Summary

This report documents all unresolved DISA Security Technical Implementation Guide (STIG) findings identified following automated remediation of a Red Hat Enterprise Linux 9 system. The findings documented herein represent exceptions requiring organizational risk acceptance, site-specific configuration, or infrastructure-level prerequisites that cannot be addressed through automated scripting alone.

Post-remediation compliance improved from 48.64% to 96.12%, a gain of +47.48 percentage points. Eighteen (18) rules remain non-compliant and are catalogued below with technical rationale, risk assessment, and recommended mitigations.

Metric	Pre-Remediation	Post-Remediation	Delta
Overall Score	48.64%	96.12%	**+47.48%**
Total Failures	262	18	244 resolved
CAT I (High)	12 failed	5 failed	7 resolved / 58%
CAT II (Medium)	228 failed	8 failed	220 resolved / 96%
CAT III (Low)	19 failed	5 failed	14 resolved / 74%
Passed Rules	174	420	+246

Key Finding: All CAT I vulnerabilities attributable to OS-level configuration have been resolved. The five (5) remaining CAT I findings require FIPS mode enablement at install time or bootloader password injection — neither of which can be safely remediated post-installation without system downtime and/or re-installation.

Scope and Methodology

Assessments were conducted using the OpenSCAP scanner against the DISA STIG profile for Red Hat Enterprise Linux 9. The baseline scan was performed against an unmodified RHEL 9 installation. Automated remediation was applied via an Ansible playbook implementing ComplianceAsCode content. The post-remediation scan was executed immediately following playbook completion.

System under assessment:

- OS: Red Hat Enterprise Linux 9
- IP Address: 192.168.186.129
- MAC Address: 00:0C:29:8B:21:F9
- Profile: xccdf_org.open-scap_testresult_xccdf_org.ssgproject.content_profile_stig
- Scan Timestamp: 2026-04-21T01:45:25-05:00
- Environment: Virtualized (VMware) — Lab/Development

Exceptions documented in this report fall into four categories:

- Infrastructure Dependencies — Requires physical infrastructure not present in a virtual/lab environment (FIPS, CAC/PKI, separate disk partitions)
- Organizational Customization — Requires site-specific values that cannot be pre-defined in a generic playbook (bootloader credentials, authorized user lists, NTP server directives)
- Functional Conflict — Automated remediation would break system functionality (user namespaces required by containerization tools)
- Tool/Version Sensitivity — The scanner detects a valid configuration using a different format or path than the expected check (SELinux sudo elevation, SSSD certmap)

Unresolved Findings — Detailed Exception Register

CAT I Findings (High Severity — 5 Remaining)

CAT I findings represent vulnerabilities whose exploitation could directly and immediately result in loss of confidentiality, integrity, or availability. The five remaining CAT I findings are all FIPS- and bootloader-related and share the same root cause: they require configuration at system installation time or require physical console access to remediate safely.

1. RHEL-09-671010 — Enable FIPS Mode

CAT I – HIGH

STIG ID	RHEL-09-671010
Rule ID	xccdf_org.ssgproject.content_rule_enable_fips_mode
CCE	CCE-88742-2
Status	Not Implemented
SRG Reference	SRG-OS-000478-GPOS-00223, SRG-OS-000396-GPOS-00176

Rule Description:

The operating system must implement NIST FIPS-validated cryptography for all cryptographic operations including data at rest and in transit. RHEL 9 must boot with the fips=1 kernel parameter and all cryptographic modules must be FIPS 140-2/140-3 validated.

Exception Rationale:

FIPS mode on RHEL 9 must be enabled at installation time via the installer's fips=1 boot parameter. Attempting to enable FIPS on a running production system requires a full reboot into a modified initramfs, regeneration of all cryptographic keys and certificates, and risks rendering the system unbootable if any non-FIPS-validated module is loaded. In a lab/virtual environment, this is an acceptable lab limitation.

Remediation Path (Production):

- During OS installation: select 'Enable FIPS mode' in the installer, or append fips=1 to the kernel boot parameters
- Post-installation (with downtime): run fips-mode-setup --enable and reboot
- Verify with: fips-mode-setup --check

Risk Assessment:

HIGH in production DoD environments. Without FIPS mode, cryptographic operations may use non-validated algorithms, violating IA-7, SC-13, and NERC CIP requirements. In this isolated lab environment, residual risk is MODERATE as there is no sensitive data at rest and no external network connectivity.

---

2. RHEL-09-671010 — Enable Dracut FIPS Module

CAT I – HIGH

STIG ID	RHEL-09-671010
Rule ID	xccdf_org.ssgproject.content_rule_enable_dracut_fips_module
CCE	CCE-86547-7
Status	Not Implemented
SRG Reference	SRG-OS-000478-GPOS-00223

Rule Description:

The dracut-fips package must be installed and the FIPS module must be included in the initramfs to ensure cryptographic validation occurs during the early boot process, before the main OS has loaded.

Exception Rationale:

This finding is directly dependent on RHEL-09-671010 (enable_fips_mode). The dracut-fips module is only active once the system's initramfs is rebuilt with FIPS support. Rebuilding the initramfs on a running virtual machine without verified FIPS kernel support risks producing an unbootable system. This exception is accepted in tandem with the FIPS mode exception above.

Remediation Path (Production):

- Install package: dnf install dracut-fips
- Regenerate initramfs: dracut -f
- Set fips=1 in grub: grubby --update-kernel=ALL --args=fips=1
- Reboot and verify: fips-mode-setup --check

Risk Assessment:

HIGH in production. Shares residual risk posture with RHEL-09-671010 above. No additional residual risk beyond the FIPS mode finding.

---

3. RHEL-09-671015 — Set crypto.fips_enabled Kernel Parameter

CAT I – HIGH

STIG ID	RHEL-09-671015
Rule ID	xccdf_org.ssgproject.content_rule_sysctl_crypto_fips_enabled
CCE	CCE-83441-6
Status	Not Implemented (kernel param not set)
SRG Reference	SRG-OS-000033-GPOS-00014, SRG-OS-000250-GPOS-00093, SRG-OS-000396-GPOS-00176

Rule Description:

The kernel parameter crypto.fips_enabled must be set to 1. This is distinct from—but dependent upon—the FIPS mode boot flag. This sysctl is only settable to 1 if the system booted with fips=1; it cannot be forced to 1 via sysctl -w on a non-FIPS-booted system.

Exception Rationale:

This finding cannot be resolved without first resolving RHEL-09-671010. The kernel sets crypto.fips_enabled=1 automatically upon a FIPS-mode boot. Attempting to set this parameter manually on a non-FIPS boot will fail silently or return an error, and the check will still fail. This is a cascading dependency exception.

Remediation Path (Production):

- Enable FIPS mode as described in RHEL-09-671010 — this parameter resolves automatically
- Verify after reboot: sysctl crypto.fips_enabled (expected: crypto.fips_enabled = 1)

Risk Assessment:

HIGH. Cascading dependency on FIPS mode. Residual risk is the same posture as RHEL-09-671010.

---

4. RHEL-09-212045 — Set Boot Loader Password (grub2)

CAT I – HIGH

STIG ID	RHEL-09-212045
Rule ID	xccdf_org.ssgproject.content_rule_grub2_password
CCE	CCE-83849-0
Status	Not Implemented
SRG Reference	SRG-OS-000080-GPOS-00048

Rule Description:

The system boot loader must require authentication prior to booting into single-user mode or a non-standard run level. A grub2 superuser password must be configured to prevent unauthorized modification of boot parameters.

Exception Rationale:

A bootloader password requires a site-specific, organizationally-approved credential. The Ansible playbook cannot inject a password hash without organizational input. In a shared lab environment, setting a bootloader password without documenting and escrowing it would create an availability risk. This is a planned configuration item for production deployment.

Remediation Path (Production):

- Generate password hash: grub2-setpassword (interactive) or grub2-mkpasswd-pbkdf2
- Add to /etc/grub.d/01_users:

```
set superusers="grubadmin"
password_pbkdf2 grubadmin grub.pbkdf2.sha512.10000.<hash>
```

- Rebuild grub config: grub2-mkconfig -o /boot/grub2/grub.cfg
- Escrow the password in the organizational PAM/vault solution

Risk Assessment:

MEDIUM in this environment. Physical console access to the hypervisor is required to exploit this gap. In production bare-metal environments, the risk is HIGH as an attacker with physical access could boot into single-user mode and bypass all OS controls.

---

5. RHEL-09-212040 — Set Boot Loader Admin Username (grub2)

CAT I – HIGH

STIG ID	RHEL-09-212040

Rule ID	xccdf_org.ssgproject.content_rule_grub2_admin_username
CCE	CCE-87370-3
Status	Not Implemented — default/blank admin username
SRG Reference	SRG-OS-000080-GPOS-00048

Rule Description:

The boot loader superuser account must not use the default username. A non-default, organizationally-defined username must be set to prevent brute-force and default-credential attacks against the bootloader authentication mechanism.

Exception Rationale:

Directly co-dependent with grub2_password (Finding 4). The username cannot be set in isolation; it must accompany the password configuration. Both settings must be defined by the organization's system administrator during initial hardening. This playbook does not inject site-specific credentials by design.

Remediation Path (Production):

- Configure in tandem with Finding 4 — replace 'grubadmin' with the organizationally-approved non-default username
- Ensure the chosen username does not appear in any default configuration file or documentation

Risk Assessment:

MEDIUM in this lab environment. HIGH in production. Default usernames reduce the attack surface complexity for targeted bootloader compromise.

CAT II Findings (Medium Severity — 8 Remaining)

CAT II findings represent vulnerabilities that, if exploited, could result in significant degradation of mission capability or could allow an unauthorized user to obtain sensitive information. Remediation for all CAT II exceptions below requires either organizational input, infrastructure changes, or involves a known scanning tool limitation.

6. RHEL-09-255070 — SSH Client FIPS 140-2 MACs (openssh.config)

CAT II – MEDIUM

STIG ID	RHEL-09-255070
Rule ID	xccdf_org.ssgproject.content_rule_harden_sshd_macs_openssh_conf_crypto_policy
CCE	CCE-86208-6
Status	Not Implemented — FIPS crypto policy inactive
SRG Reference	SRG-OS-000125-GPOS-00065, SRG-OS-000250-GPOS-00093

Rule Description:

The SSH client must be configured to use only FIPS 140-2 validated Message Authentication Codes (MACs). OpenSCAP verifies that the system crypto policy enforces FIPS-compliant MACs in /etc/crypto-policies/back-ends/openssh.config.

Exception Rationale:

This finding is a cascading dependency of the FIPS mode findings (CAT I, Findings 1-3). The FIPS crypto policy back-end is only active when the system is running in FIPS mode. Without fips=1 at boot, the crypto-policies subsystem falls back to DEFAULT or FUTURE policy, which permits non-FIPS MACs. This check will pass automatically once FIPS mode is enabled.

Remediation Path (Production):

- Enable FIPS mode (see Finding 1) — this finding resolves automatically
- Alternatively, manually set: update-crypto-policies --set FIPS
- Verify: update-crypto-policies --show

Risk Assessment:

MEDIUM. The DEFAULT crypto policy still enforces strong MACs (hmac-sha2-256, hmac-sha2-512). The gap is the absence of FIPS-certified validation, not the absence of strong algorithms.

---

7. RHEL-09-255075 — SSH Server FIPS 140-2 MACs (opensshserver.config)

CAT II – MEDIUM

STIG ID	RHEL-09-255075
Rule ID	xccdf_org.ssgproject.content_rule_harden_sshd_macs_opensshserver_conf_crypto_policy
CCE	CCE-87567-4
Status	Not Implemented — FIPS crypto policy inactive
SRG Reference	SRG-OS-000125-GPOS-00065, SRG-OS-000250-GPOS-00093

Rule Description:

The SSH server (sshd) must be configured to restrict MACs to FIPS 140-2 validated algorithms only, as enforced in /etc/crypto-policies/back-ends/opensshserver.config.

Exception Rationale:

Same cascading FIPS dependency as Finding 6. This check validates the server-side crypto policy back-end, which is also only populated with FIPS-approved MACs when the system is in FIPS mode.

Remediation Path (Production):

- Enable FIPS mode (Finding 1) — this finding resolves automatically
- Verify sshd MAC configuration: sshd -T | grep macs

Risk Assessment:

MEDIUM. SSH daemon is operational and uses strong algorithms under the DEFAULT policy. FIPS certification is the gap, not algorithm strength.

---

8. RHEL-09-231035 — /var/tmp on Separate Partition

CAT II – MEDIUM

STIG ID	RHEL-09-231035
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_var_tmp
CCE	CCE-83487-9
Status	Not Implemented — Installation-time configuration required
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /var/tmp directory must be on a separate partition or logical volume to prevent a denial of service condition from disk space exhaustion affecting the root filesystem or other critical filesystems.

Exception Rationale:

/var/tmp must be defined as a separate mount point at installation time. Re-partitioning a running system requires unmounting the filesystem, which may conflict with active processes. This cannot be automated post-install without significant downtime and data migration. In a virtual machine, the disk layout was set at provisioning time.

Remediation Path (Production):

- At installation: define /var/tmp as a separate LVM logical volume during the disk layout phase
- Post-installation (with downtime): create new LV, copy data, bind mount, update /etc/fstab
- Alternatively, use a bind mount from a tmpfs: add to /etc/fstab:

```
tmpfs  /var/tmp  tmpfs  defaults,noatime,nosuid,nodev,noexec,size=2G  0 0
```

Risk Assessment:

MEDIUM. Without partition isolation, a runaway process writing to /var/tmp could fill the root filesystem, causing system instability. In a single-user lab environment with monitored storage, the immediate risk is LOW.

---

9. RHEL-09-411095 — Only Authorized Local Users Exist

CAT II – MEDIUM

STIG ID	RHEL-09-411095
Rule ID	xccdf_org.ssgproject.content_rule_accounts_authorized_local_users
CCE	CCE-88048-4

Status	Requires Site-Specific Configuration
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

Only organizationally-authorized local user accounts may exist on the operating system. The scanner checks /etc/passwd against an approved user list. Any user not on the approved list causes the check to fail.

Exception Rationale:

The STIG check requires a site-specific list of authorized users to be pre-configured in the OVAL definition or variable file. Without injecting this organizational list into the playbook, the scanner cannot determine which accounts are 'authorized.' This is expected in any fresh RHEL installation and must be customized per deployment.

Remediation Path (Production):

- Define the authorized user list in the OpenSCAP variable: var_accounts_authorized_local_users_regex
- Lock or remove all non-essential accounts: passwd -l <username> or userdel <username>
- Verify remaining accounts are explicitly approved in the system's accreditation documentation

Risk Assessment:

MEDIUM. Unauthorized local accounts provide a potential persistence vector for adversaries. In this lab environment with no external access, residual risk is LOW but the finding should be resolved before any production deployment.

---

10. RHEL-09-213105 — Disable User Namespaces

CAT II – MEDIUM

STIG ID	RHEL-09-213105
Rule ID	xccdf_org.ssgproject.content_rule_sysctl_user_max_user_namespaces_no_remediation
CCE	CCE-86209-4
Status	Intentionally Not Implemented — Functional Dependency
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The kernel parameter user.max_user_namespaces must be set to 0 to prevent unprivileged users from creating user namespaces, which can be abused to escalate privileges.

Exception Rationale:

This rule intentionally has no automated remediation in the SSG playbook (as indicated by the rule name suffix _no_remediation). Setting user.max_user_namespaces=0 breaks container runtimes including Podman, Docker, and systemd-nspawn that rely on unprivileged user namespaces. In any environment where containers are used, applying this setting would render the container runtime non-functional. The risk of the control must be weighed against the operational requirement.

Remediation Path (If Accepted):

```
echo 'user.max_user_namespaces = 0' >> /etc/sysctl.d/99-stig.conf
sysctl --system
```

- NOTE: This will break any container workloads. Verify no container runtime is present or required before applying.

Risk Assessment:

MEDIUM. User namespaces have been associated with several kernel privilege escalation CVEs. However, disabling them without a container audit is an operational risk. Recommend documenting this as a formal risk acceptance if containers are operationally required.

---

11. RHEL-09-431016 — Elevate SELinux Context for Sudo

CAT II – MEDIUM

STIG ID	RHEL-09-431016
Rule ID	xccdf_org.ssgproject.content_rule_selinux_context_elevation_for_sudo
CCE	CCE-86576-6
Status	Possible Scanner False Positive / Partial Implementation
SRG Reference	SRG-OS-000324-GPOS-00125

Rule Description:

The operating system must elevate the SELinux context when an administrator calls the sudo command. This requires the use_pty and rolespec_copy options in the sudoers configuration.

Exception Rationale:

The Ansible playbook configures sudo with the required SELinux options. However, the OpenSCAP check may be looking for a specific configuration format or file path that differs from the configuration written by the playbook. This is a known intermittent issue with SSG checks that validate sudoers drop-in files in /etc/sudoers.d/ versus the monolithic /etc/sudoers file.

Verification Steps:

- Check sudo configuration: sudo -V | grep 'SELinux'
- Verify sudoers: visudo -c && grep -r 'use_pty\|rolespec_copy' /etc/sudoers /etc/sudoers.d/
- If configured correctly, document as a scanner tool limitation and accept the finding

Risk Assessment:

MEDIUM if genuinely not configured. LOW if this is a false positive. The SELinux context elevation prevents privilege escalation via sudo in restricted SELinux domains. Recommend manual verification before accepting.

---

12. RHEL-09-252020 — Chrony Server Directive Configuration

CAT II – MEDIUM

STIG ID	RHEL-09-252020
Rule ID	xccdf_org.ssgproject.content_rule_chronyd_server_directive
CCE	CCE-87077-4
Status	Requires Organizational NTP Infrastructure
SRG Reference	SRG-OS-000355-GPOS-00143, SRG-OS-000356-GPOS-00144, SRG-OS-000359-GPOS-00146

Rule Description:

Chrony must be configured with only the server directive (not pool) for time synchronization. Time sources must be explicitly defined as approved DoD NTP servers using server directives, not pool directives which dynamically resolve to unknown peers.

Exception Rationale:

The default chrony configuration uses pool directives pointing to public NTP pool servers, which is appropriate for non-DoD environments. In a lab environment without access to DoD NTP infrastructure (e.g., tick.usno.navy.mil, tock.usno.navy.mil), replacing pool with server directives would break time synchronization entirely. This requires organizational NTP server addresses to configure correctly.

Remediation Path (Production):

- Edit /etc/chrony.conf — replace pool directives with server directives pointing to DoD-approved NTP sources:

```
server tick.usno.navy.mil iburst
server tock.usno.navy.mil iburst
```

- Remove all pool lines
- Restart chronyd: systemctl restart chronyd
- Verify: chronyc sources

Risk Assessment:

MEDIUM. Using pool directives introduces the risk of synchronizing with unvalidated time sources, which could be exploited to cause time-of-day attacks against Kerberos, TLS, or audit log integrity. In an isolated lab, residual risk is LOW.

---

13. RHEL-09-631015 — Enable Certmap in SSSD

CAT II – MEDIUM

STIG ID	RHEL-09-631015
Rule ID	xccdf_org.ssgproject.content_rule_sssd_enable_certmap
CCE	CCE-89737-1
Status	Not Implemented — Requires PKI/CAC Infrastructure
SRG Reference	SRG-OS-000068-GPOS-00036

Rule Description:

SSSD must be configured to verify the certificate of the user or group through a certmap rule in /etc/sssd/sssd.conf. This supports DoD Common Access Card (CAC) and PKI-based authentication.

Exception Rationale:

Certificate mapping in SSSD requires an operational PKI infrastructure including a Certificate Authority, issued user certificates, and a configured identity domain in SSSD. A home lab or development environment lacks DoD-issued CAC cards and the supporting PKI chain. This is a production-only configuration item.

Remediation Path (Production):

- Ensure sssd and sssd-tools are installed: dnf install sssd sssd-tools
- Configure a [certmap/<domain>/<rulename>] section in /etc/sssd/sssd.conf with the appropriate matchrule and maprule for your PKI
- Integrate with AD/LDAP identity provider and the organization's PKI certificate chain
- Restart sssd: systemctl restart sssd

Risk Assessment:

MEDIUM. Without certmap, the system falls back to password-based authentication only. In a DoD production environment, this is non-compliant with IA-5(2) requirements for PKI-based authentication. In this isolated lab, no PKI infrastructure exists; risk acceptance is appropriate.

CAT III Findings (Low Severity — 5 Remaining)

CAT III findings represent vulnerabilities that, while technically non-compliant, present minimal direct risk to operations. They are included for completeness and to ensure full auditability. All five CAT III findings relate to disk partitioning and require installation-time configuration.

14. RHEL-09-231010 — /home on Separate Partition

CAT III – LOW

STIG ID	RHEL-09-231010
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_home
CCE	CCE-83468-9
Status	Not Implemented — Disk Layout Set at Installation
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /home filesystem must be on its own partition or logical volume to prevent user data from filling system-critical filesystems.

Exception Rationale:

Disk partitioning is an installation-time decision. The VM was provisioned with a single root partition. Re-partitioning requires unmounting /home, which is not possible on a running system without significant downtime.

Remediation Path (Production):

- Define at installation: allocate a dedicated LVM LV for /home (recommended minimum: 10% of available storage or 10GB)
- Post-install migration: create new LV, rsync /home, update /etc/fstab, remount

Risk Assessment:

LOW. In a single-user lab VM, a full /home would affect the root filesystem but not cause a production outage. No sensitive user data is present.

---

15. RHEL-09-231015 — /tmp on Separate Partition

CAT III – LOW

STIG ID	RHEL-09-231015
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_tmp
CCE	CCE-90845-9
Status	Not Implemented — Disk Layout Set at Installation
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /tmp filesystem must be on its own partition or logical volume, configured with nodev, nosuid, and noexec mount options to prevent abuse.

Exception Rationale:

Same root cause as /home partitioning. /tmp must be defined at install time. Note that /tmp can be mounted as a tmpfs post-installation as an alternative compliance path.

Remediation Path (Production):

- Preferred alternative — mount as tmpfs (does not require repartitioning):

```
systemctl enable --now tmp.mount
```

- Verify: findmnt /tmp

Risk Assessment:

LOW. Without noexec on /tmp, attackers could write and execute malicious binaries in /tmp. In an isolated lab, this is a minor risk.

---

16. RHEL-09-231020 — /var on Separate Partition

CAT III – LOW

STIG ID	RHEL-09-231020
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_var
CCE	CCE-83466-3
Status	Not Implemented — Disk Layout Set at Installation
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /var filesystem must be on a separate partition to prevent log data, package data, or spool files from consuming the root filesystem.

Exception Rationale:

Installation-time dependency. /var cannot be moved on a running system without system downtime. This is a pre-provisioning configuration item.

Remediation Path (Production):

- Define at installation: allocate a dedicated LVM LV for /var (recommended: 20-30% of disk or 20GB minimum for log-heavy systems)

Risk Assessment:

LOW. /var hosts syslog, audit logs, and package caches. Filling /var would prevent logging, which is a serious issue in production. In a monitored lab environment, risk is LOW.

---

17. RHEL-09-231025 — /var/log on Separate Partition

CAT III – LOW

STIG ID	RHEL-09-231025
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_var_log
CCE	CCE-90848-3
Status	Not Implemented — Disk Layout Set at Installation
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /var/log filesystem must be on a dedicated partition to prevent log flooding from filling other filesystems and to protect log integrity.

Exception Rationale:

Installation-time dependency. /var/log is the most critical partition to isolate in high-security environments because audit log exhaustion can trigger an emergency system shutdown (auditd halt-on-failure). This should be a top priority in any production deployment.

Remediation Path (Production):

- Define at installation: allocate a dedicated LVM LV for /var/log (recommended: 10-15GB minimum, or based on audit retention policy)
- Configure auditd admin_space_left and action in /etc/audit/auditd.conf to prevent uncontrolled disk fill

Risk Assessment:

LOW in lab. MEDIUM in production. An unprotected /var/log risks audit log overflow, which in strict auditd configurations (admin_space_left_action = halt) would cause a system shutdown — a self-imposed availability denial.

---

18. RHEL-09-231030 — /var/log/audit on Separate Partition

CAT III – LOW

STIG ID	RHEL-09-231030
Rule ID	xccdf_org.ssgproject.content_rule_partition_for_var_log_audit
CCE	CCE-90847-5
Status	Not Implemented — Disk Layout Set at Installation
SRG Reference	SRG-OS-000480-GPOS-00227

Rule Description:

The /var/log/audit filesystem must be on a dedicated partition or logical volume to ensure audit log data cannot be crowded out by other logs or processes and to maintain DoD audit record integrity requirements.

Exception Rationale:

Installation-time dependency. /var/log/audit is specifically called out in DoD STIGs as the most critical partition for non-repudiation and audit trail integrity. In production, this must always be on its own dedicated partition with quota enforcement. This is the highest-priority partition exception in this report.

Remediation Path (Production):

- Define at installation: dedicate a separate LVM LV for /var/log/audit (DoD minimum: 10GB; recommendation: size to store 30 days of audit records based on audit event rate)
- Configure /etc/audit/auditd.conf:

```
space_left_action = email
admin_space_left_action = halt
max_log_file_action = rotate
```

Risk Assessment:

LOW in isolated lab. HIGH in production DoD environments. Audit log integrity is a non-negotiable compliance requirement. Without isolation, a single rogue process could fill disk and eliminate the audit trail — a severe non-repudiation failure.

Risk Acceptance Summary Matrix

The following table summarizes the residual risk posture for each unresolved finding and provides the recommended disposition for both the current lab environment and a future production deployment.

Finding	Title	CAT	Lab Risk	Prod Risk	Disposition
1	Enable FIPS Mode	I	MOD	HIGH	Accept/Defer
2	Enable Dracut FIPS Module	I	MOD	HIGH	Accept/Defer
3	crypto.fips_enabled = 1	I	MOD	HIGH	Cascading
4	grub2 Bootloader Password	I	LOW	HIGH	Plan
5	grub2 Admin Username	I	LOW	HIGH	Plan
6	SSH Client FIPS MACs	II	LOW	MED	Cascading
7	SSH Server FIPS MACs	II	LOW	MED	Cascading
8	/var/tmp Partition	II	LOW	MED	Plan
9	Authorized Local Users	II	LOW	MED	Plan
10	User Namespaces	II	MED	MED	Risk Accept
11	SELinux Sudo Context	II	LOW	MED	Verify
12	Chrony Server Directive	II	LOW	MED	Plan
13	SSSD Certmap	II	LOW	MED	Plan
14	/home Partition	III	LOW	LOW	Plan
15	/tmp Partition	III	LOW	LOW	Plan
16	/var Partition	III	LOW	LOW	Plan
17	/var/log Partition	III	LOW	MED	Plan
18	/var/log/audit Partition	III	LOW	HIGH	Plan

Disposition Key:

- Accept/Defer — Risk formally accepted; implement at next system rebuild or major maintenance window
- Plan — Requires organizational input or infrastructure; schedule for next deployment cycle
- Cascading — Will auto-resolve when parent finding is remediated
- Risk Accept — Formal risk acceptance required; functional dependency prevents implementation
- Verify — Manual verification recommended; may be a scanner false positive

Recommendations

Immediate Actions (Lab Environment)

- Accept current 96.12% compliance for lab/demonstration purposes — this score demonstrates a mature automated hardening capability
- Document all 18 exceptions in the system's Plan of Action and Milestones (POA&M) with target resolution dates
- Perform manual verification of Finding 11 (SELinux sudo context) to rule out a false positive before accepting
- Verify chrony time synchronization is operational despite the server directive exception

Pre-Production Checklist

- Enable FIPS mode at OS installation time — this resolves Findings 1, 2, 3, 6, and 7 (five findings resolved by one architectural decision)
- Define disk partition layout before provisioning — /home, /tmp, /var, /var/log, /var/log/audit as separate LVs (resolves Findings 14-18 and Finding 8)
- Configure grub2 bootloader credentials using organizationally-approved non-default username and PBKDF2-hashed password (resolves Findings 4 and 5)
- Inject authorized user list into the OpenSCAP variable file and remove non-standard accounts (resolves Finding 9)
- Configure site-specific NTP server directives using approved DoD time sources (resolves Finding 12)
- Integrate with organizational PKI/CAC infrastructure and configure SSSD certmap (resolves Finding 13)
- Conduct a container workload audit before deciding on user namespace policy (Finding 10)

Continuous Monitoring

- Schedule monthly OpenSCAP re-scans to detect configuration drift
- Integrate scan results into a SIEM or GRC platform for trending and POA&M tracking
- Review the DISA STIG update feed quarterly — RHEL 9 STIG is actively maintained and new rules are added with each revision
- Implement auditd log rotation and remote syslog forwarding to a separate log aggregator before any production deployment

Conclusion

This automated hardening pipeline has demonstrated a repeatable, auditable approach to DISA STIG compliance for RHEL 9. The remediation effort resolved 244 of 262 identified vulnerabilities — a 93.1% resolution rate — and eliminated all CAT I vulnerabilities addressable through OS-level configuration.

The 18 remaining findings are not failures of the remediation process. They are well-understood, documented exceptions that fall into predictable categories: FIPS infrastructure dependencies, installation-time disk layout decisions, and organizational policy items that require human input. This is the expected outcome of any automated STIG remediation tool applied to a generic OS installation.

Compliance is not binary — a 96.12% score with a clear, documented exception register demonstrates stronger security governance than a 100% score with no documentation of why exceptions exist. The key deliverable of this assessment is not the number, but the paper trail: each finding has a rationale, a remediation path, and a risk assessment that enables informed decision-making by the Authorizing Official (AO).

Key Achievement

All high-severity vulnerabilities addressable through OS-level configuration have been eliminated. The system's residual CAT I risk is limited exclusively to FIPS cryptographic mode and bootloader authentication — both of which are architectural requirements to be built into the next provisioning cycle.

Prepared By:	Review Date:
David Perez	21 April 2026